SUPPLY-CHAIN FIELD GUIDE: THE 94-MINUTE WINDOW
OVHcloud CLI Hijack â€” 19 October 2026
==========

EXECUTIVE SUMMARY

On 19 October 2026, a threat actor hijacked a contributor account of the OVHcloud CLI (Open Virtual Host Command Line Interface), a widely used infrastructure management tool. Between 12:47 and 14:21 UTC â€” a 94-minute window â€” five existing release archives were silently swapped with malicious builds.

The attack targeted macOS, Linux, and Windows users across all major CPU architectures (x86-64, ARM64). The payload was a credential stealer that harvested secrets from compromised developer machines and CI/CD runners.

CRITICAL INSIGHT: SOURCE CODE, TAGS, AND BUILD PIPELINES REMAINED UNTOUCHED.
Only the pre-built binary artifacts attached to GitHub Releases were replaced. Any code review of the repository would have found nothing.

THE ATTACK CHAIN

Phase 1 â€” Credential Compromise (T1078)
- Contributor account with release-publishing rights was taken over.
- Likely vector: phishing or session token theft (not confirmed).

Phase 2 â€” Artifact Swap (T1489)
- Five existing release archives (v0.13.x through v0.15.x) were deleted and replaced with malicious builds.
- Original GitHub Releases are mutable by default; maintainers can edit attachments post-publication.
- New archives carried the same version numbers and commit hashes.

Phase 3 â€” Deployment (T1195)
- Users running 'ovh update' or downloading from the Releases page received the compromised binaries.
- No hash verification was performed by the update mechanism.

Phase 4 â€” Collection (T1552)
- Credential stealer activated on execution.
- Harvested targets: ~/.aws/credentials, ~/.ssh/id_rsa, ~/.ssh/id_ed25519, .env files, GITHUB_TOKEN, OVHCLOUD_TOKEN, DOCKER_CONFIG.
- Exfiltrated to command-and-control servers via HTTPS POST.

Phase 5 â€” Persistence (T1098)
- Stealer installed a launchd/systemd service for re-infection.

- SSH keys were copied to hidden directories for lateral movement.

TIMELINE (UTC)

12:47 First malicious archive uploaded
13:02 Second archive replaced (v0.14.x)
13:21 Third archive replaced (v0.15.0)
13:44 Fourth archive replaced (v0.15.1)
14:08 Fifth archive replaced (v0.15.2)
14:21 Maintainer detects anomaly, disables Releases
14:57 GitHub Support notified
15:30 Immutable Release v0.16.0 published as fix

Total exposure window: 94 minutes.

IMMEDIATE ACTIONS (for affected teams)
---
1. ROTATE all credentials stored on developer machines with CLI access.
2. AUDIT SSH keys: revoke any key that touched a machine with OVHcloud CLI.
3. CHECK CI/CD logs for suspicious downloads between 12:47â€“14:21 UTC.
4. ENABLE GitHub artifact attestations for all repositories.
5. IMPLEMENT release immutability on your own GitHub organization.

DETECTION SIGNALS

- SHA256 mismatch between locally built artifact and GitHub Release.
- Unexpected network connections from CLI tools (C2 beacon).
- Credential file access by non-shell processes.
- Launchd/systemd services created by CLI tools.

LESSONS FOR MAINTAINERS

The OVHcloud CLI incident demonstrates a fundamental weakness in
open-source distribution: the gap between source trust and binary trust.

Key takeaways:

1. RELEASE IMMUTABILITY IS NON-NEGOTIABLE
GitHub supports immutable releases since 2025. Enable it. Once
published, a release cannot be modified â€” by anyone, including you.

2. ARTIFACT SIGNING IS THE ONLY REAL GATE
Code review validates source. It does not validate binaries. Sign
every artifact with Sigstore/cosign or GPG. Verify signatures in CI
before deployment.

3. PROVENANCE ATTESTATION BEATS TRUST

SLSA (Supply-chain Levels for Software Artifacts) Level 3 requires build provenance â€” a signed statement of where and how an artifact was built. Implement SLSA Level 3 for critical infrastructure tools.

4. DISTRIBUTED BUILD SYSTEMS REDUCE BLAST RADIUS
Reproducible builds allow independent verification. If three independent builds produce identical binaries, tampering is detectable.

5. LIMIT RELEASE-ACCOUNT PRIVILEGES
Two-person rule for release publishing. Rotate tokens frequently. Use short-lived credentials for CI/CD.

ATTACK SURFACE MAP

Account compromise â†’ Release edit â†’ User download â†’ Credential theft â†’ Lateral movement â†’ Infrastructure compromise.

Each arrow represents a control point:
- Account compromise: MFA, hardware keys, session monitoring.
- Release edit: Immutability, audit logging.
- User download: Hash verification, signature checking.
- Credential theft: Secret managers, short-lived tokens.
- Lateral movement: Network segmentation, egress filtering.

CLOSING

The tag is not the artifact. The artifact is the artifact.

Trust the cryptographic proof, not the version number.

Report: ERR.SYS Field Guide 001
Date: 20 October 2026
Source: The Hacker News, 19 October 2026
Classification: TLP:CLEAR